## EWB COURSES

# ASSESSMENT 01

## SECURITY FOUNDATIONS

Individual Assessment

| | |
|---|---|
| **Student Name** | Zeeshan Ali Sheikh |
| **Course** | Ewb AI POWERED CYBERSECURITY |
| **Batch** | Batch 1 |
| **Assessment Issued** | 18 October 2026 |
| **Prepared** | 4 November 2026 |

*Prepared from the supplied EWB Assessment 01 brief and its listed reference reading.*
*All scenarios and log entries are treated as fictional training evidence.*

# Task A | Secure a student account

Scenario focus: Mira reuses a short password, approves unexpected sign-in prompts, delays updates, stores her only project copy on one laptop, and shares that laptop while signed in.

## A1-A2. Risks, controls and limitations

| Risk | Asset at risk | CIA impact | Practical control | Limitation |
|---|---|---|---|---|
| 1. Short, reused password | Email and learning-portal accounts | Confidentiality: messages and records may be exposed. Integrity: an intruder could change profile or academic information. Availability: accounts may be locked. | Replace it with a long, unique password for each account; use a password manager. | A manager still needs a strong master password. A unique password does not stop phishing by itself. |
| 2. Approving unexpected MFA prompts | Learning portal and linked account | Confidentiality and integrity: an unauthorised sign-in may succeed and allow viewing or changing data. | Deny prompts Mira did not initiate, report repeated prompts, and use number matching or a passkey/security key where available. | MFA can still be defeated by social engineering or a user approving the wrong prompt. |
| 3. Delayed device updates | Laptop, saved files and browser sessions | Confidentiality, integrity and availability may be affected if attackers exploit a known software weakness. | Install operating-system, browser and application security updates promptly; enable automatic updates. | Updates reduce known risks but cannot remove every vulnerability or protect against every malicious file. |
| 4. Only one project copy | Project files and coursework | Availability: laptop loss, disk failure, theft or ransomware could remove the only copy. Integrity may also be affected by corruption. | Keep an automatic backup on a separate drive or trusted cloud storage and test that files can be restored. | A connected or synchronised backup can also copy unwanted changes or deletion; restore tests are important. |
| 5. Friend uses Mira's signed-in account | Email, portal data and project files | Confidentiality: the friend may see private data. Integrity: files or submissions could be changed or deleted. | Use separate operating-system accounts, lock the screen, and sign out of personal services before sharing the laptop. | A separate account is only effective when permissions are configured correctly; physical access remains a risk. |

## Priority order

1. Stop and deny unexpected sign-in prompts immediately, then report repeated prompts. This is first because a prompt approval can allow an active unauthorised login.
2. Change the reused password to a unique one from a trusted device, secure the email account, and revoke unfamiliar sessions. Email is especially important because it may be used to reset other accounts.
3. Install pending security updates and set up a separate, tested backup. These reduce exploitation risk and protect the availability of coursework; separate laptop accounts should also be configured before sharing the device again.

## A3. Authentication versus authorisation

Authentication checks who is signing in. For Mira, the learning portal may verify her identity through her username, a unique password and a second factor. Authorisation happens after identity is verified: it decides what that account is allowed to do. For example, Mira may be allowed to view her own attendance and marks and upload her assignments, but not to edit another student's marks or access lecturer-only functions. In short, authentication is "Who are you?" and authorisation is "What are you allowed to do?"

# Task B | Analyse a suspicious message

Assessment note: the addresses use the fictional .example domain. The points below identify warning signs in the supplied text; they do not prove that a real sender or website is malicious.

## B1. Warning-sign table

| Evidence | Quoted phrase | Why it needs scrutiny |
|---|---|---|
| Sender address | “awards@campus-awards.example” | The normal college domain is stated as campus.example. The similar-looking campus-awards name is not the same domain and needs independent checking. |
| Reply-To mismatch | “help@personal-awards.example” | Replies would go to a different, personal-looking domain rather than the college domain shown in the scenario. |
| Artificial urgency | “FINAL WARNING” / “expires in 20 minutes” | A short deadline pressures the student to act before checking with the college. |
| Credential and MFA request | “enter your college password and OTP” | A message asking for both a password and a one-time code could capture credentials and help an attacker complete sign-in. |
| Isolation and identity-data request | “Do not contact the college office” / “photo of your identity card” | It discourages independent verification while asking for sensitive identity information. A legitimate process should be confirmed through an official channel. |

## B2. Safe verification process

1. Do not click the message link, reply, call a number in the message, or provide a password, OTP or identity document.
2. Open the college portal using a bookmark or an address independently taken from the college’s official website or published student materials. Check for a scholarship notice after signing in normally.
3. Contact the scholarship or IT office using a phone number or email address obtained independently from the official college website or student handbook. Ask whether the award and sender are genuine.

HTTPS only encrypts the connection between the browser and the site; it does not prove that the site belongs to the college or that its content is honest. A familiar display name can also be chosen by a sender and is not reliable proof of identity.

## B3. If the student already entered a password and OTP

1. From a trusted device, change the exposed password immediately through the independently verified official portal. Change it anywhere else it was reused, starting with email, and do not send the old or new password to anyone.
2. Contact the college IT/security team through an official channel and report that both a password and OTP were entered. Ask the team to revoke active sessions/tokens, review sign-in events and help reset MFA if needed.
3. Preserve the message and its details (sender, reply-to, time and full headers if available) for the authorised team. Do not forward the link to classmates or visit it for testing.
4. After containment, review recent sign-ins, recovery details, MFA methods, mailbox forwarding rules and portal activity for unfamiliar changes. Report any identity document already shared through the college’s official process.

## B4. What cannot be established

The text alone cannot confirm who sent the message or whether the sender address was spoofed. Full email headers (including SPF/DKIM/DMARC results) and independent confirmation from the college would help.

# Task C | Triage a sign-in alert

Evidence context: all timestamps are IST on 18 October 2026. The assessment identifies 192.0.2.10 as the usual classroom egress and explicitly warns that a different IP alone does not identify an attacker.

## C1. Four-point timeline

| Time | Observed event | Interpretation |
|---|---|---|
| 09:00-09:01 | Observed: student07 password succeeded and MFA was approved from 192.0.2.10. | This matches the stated usual classroom egress. It provides a baseline successful sign-in. |
| 10:14-10:15 | Observed: two password attempts failed from 198.51.100.23. | Repeated failures may indicate guessing or an incorrect password, but the events alone do not identify who made them. |
| 10:16-10:18 | Observed: password succeeded, MFA was denied, then MFA was approved from 198.51.100.23. User says they approved a prompt around 10:18 but did not intend to sign in. | The password may have been known to another party and the user's mistaken approval may have completed the MFA step. This is an interpretation, not proof of the actor. |
| 10:20 | Observed: a session was created from 198.51.100.23. | The sequence is consistent with a successful session after the MFA approval. The IP address does not establish a person or physical location. |

## C2. Likely explanation, alternative and checks

Likely explanation: another party may have known the password through reuse, phishing or guessing. Two failures were followed by a success. After the MFA denial, the student approved an unexpected prompt, and a session was created. This suggests prompt fatigue or mistaken approval, but it does not prove who initiated the login.

Alternative: a legitimate device, VPN or shared network path, or a logging mismatch, may explain the unfamiliar IP. The log lacks device/browser details.

Checks: (1) compare device ID, browser/user-agent and session details with the student's known devices; (2) review detailed MFA/session audit records and post-10:20 activity, then confirm the timeline with the student through a trusted channel.

## C3. Three prioritised actions for Authorized IT

1. Preserve authentication, MFA, session and audit logs with timestamps and device/context fields in a restricted, read-only record. Do not delete them.
2. Revoke sessions/tokens; temporarily block the account if needed; reset the password and review or re-enrol MFA. Verify recovery methods and registered devices with the student.
3. Review post-10:20 activity, profile/recovery changes and accessed data. Record findings, notify the security contact and monitor repeat attempts before restoring access.

## C4. Incident summary (60-100 words)

On 18 October 2026, student07 signed in from the usual classroom egress at 09:00-09:01. At 10:14-10:15, two password attempts failed from 198.51.100.23, followed by password success, an MFA denial, an approval and session creation at 10:20. The student says they approved the prompt by mistake and did not initiate a login. This raises concern about account compromise, but the IP does not identify a person. Preserve logs, revoke sessions and check device/MFA context.

# Task D | Review an AI security answer

The fictional AI output contains unsafe conclusions and unsafe instructions. Each correction below is based on the supplied message/log evidence and the reference reading listed by EWB.

## D1. Five claims/actions to correct

| AI claim/action | Correction |
|---|---|
| "The email is safe because it uses HTTPS." | Incorrect. HTTPS protects data in transit but does not prove the destination is controlled by the college or that the message is genuine. Verify through an independently obtained college portal/contact. |
| "The person using 198.51.100.23 stole the password." | Unsupported attribution. The logs show events associated with that documentation IP, not the identity of a person or how the password was obtained. Check device, browser, MFA and session context. |
| "MFA prevents every account compromise." | False. MFA reduces risk, but the supplied timeline shows an MFA denial followed by an approval after the student says they approved a prompt by mistake. Users can be deceived into approving a request. |
| "Delete the suspicious logs." | Unsafe. Logs are evidence needed to understand and investigate the event. Preserve relevant authentication, MFA and session records in a restricted incident record. |
| "Send the student's password to support." | Unsafe. Passwords and OTPs must not be shared with support or another person. Reset credentials through the verified official process and ask IT to revoke sessions and investigate. |

## D2. Safer prompt for an AI tool

"Analyse only the fictional message text and synthetic sign-in log supplied below. Do not browse, visit any URL, or infer facts that are not present. Separate (1) directly observed facts, (2) reasonable interpretations, and (3) unknowns. Explain why HTTPS and a display name do not establish sender legitimacy. Do not identify a person from an IP address. Do not request or reproduce passwords, OTPs, identity documents or other secrets. Recommend proportionate actions for an authorised IT team, including evidence preservation and account containment. State uncertainty clearly, and identify what additional log or email-header evidence would help distinguish the possible explanations."

## D3. Corrected security advice (100-150 words)

Do not trust the scholarship message or enter credentials through its link. The sender address differs from the college's normal domain, the reply-to address is different, and the message creates urgency while asking for a password, OTP and identity-card photo. Verify the scholarship by opening the college portal from a saved or independently confirmed address and contacting the office through details published by the college. HTTPS protects a connection but does not prove that a website is genuine. In the sign-in log, the password success, MFA approval and session creation are concerning, especially because the student says the prompt was approved by mistake. However, the IP address does not identify a person. Preserve logs, revoke sessions, reset credentials securely and review account activity.

## D4. AI-use Declaration and Evidence/Reference Notes

AI-use declaration:

Gemini was used to help and check grammar, structure, clarity and for reviewing this prepared document. The supplied scenarios and synthetic log were the only case evidence used. No real password, OTP, identity document or personal account data was provided.

Evidence / reference notes:

- Assessment evidence: the synthetic log records password success at 10:16, MFA denied at 10:17, MFA approved at 10:18 and session created at 10:20 from 198.51.100.23; the student statement says the prompt was approved by mistake. These facts support concern but do not identify an actor.
- CISA, Secure Our World: the EWB brief lists this for basic account and phishing guidance, including safer passwords, MFA, updates and recognizing/reporting phishing. https://www.cisa.gov/secure-our-world
- NIST, Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (AI 600-1): the EWB brief lists this reference for risks such as confabulation and the need to verify AI-generated information. https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf